Studio Nx

백엔드 158 — get_current_user() 재설정 이전 로그인 거부

2026-10-14

백엔드 158 — `get_current_user()`에 재설정 이전 로그인 거부 연결

항목	내용
파일	`studionx/backend/app/api/deps.py`의 `get_current_user()`
작업	P1-28 비밀번호 찾기 (FR-118): 아홉 번째 함수 (기존 함수에 검사 하나를 더함)
작성	Claude (AI), 2026-10-15, 사용자 검토
이전	157 `decode_token_with_iat()`
시험	`tests/test_deps.py` 6개 추가(파일 전체 19개), `tests/test_password_reset_service.py` 1개 추가
다음	`/auth/refresh`(리프레시 토큰)에 같은 검사를 연결

1. 하는 일

로그인이 필요한 모든 API가 거치는 `get_current_user()`에서, 비밀번호를 재설정하기 **전에** 발급된 액세스 토큰을 **401**로 거부합니다. 그 계정에 이미 로그인해 있던 다른 기기나 도난당한 토큰이 재설정 뒤에는 쓸 수 없게 됩니다.

상황	결과
재설정한 적 없는 계정의 토큰	그대로 통과 (기존 로그인은 영향 없음)
재설정 **이전**에 발급된 토큰	401 "Please sign in again." (다른 401과 같은 문구)
재설정 **이후**(같은 초 포함)에 발급된 토큰	통과
재설정한 계정인데 `iat`가 없는 토큰	401

2. 바뀐 코드

```
user_id, issued_at = decode_token_with_iat(credentials.credentials, "access")   # decode_access_token에서 교체
user = db.get(User, user_id)
if user is None or user.status != "ACTIVE":
    raise AppError(ErrorCode.UNAUTHORIZED, 401, "Please sign in again.")
if issued_before_password_change(issued_at, user.password_changed_at):          # 새로 더한 검사
    raise AppError(ErrorCode.UNAUTHORIZED, 401, "Please sign in again.")
return user
```

3. 왜 이렇게

선택	이유
같은 401, 같은 문구	다른 이유(만료, 없는 회원)와 구분되지 않게 해서, 응답으로 "비밀번호가 바뀌었다"는 사실을 알아낼 수 없습니다
회원 상태 검사 **뒤**에 둠	회원이 없거나 탈퇴 계정이면 `user.password_changed_at`을 읽기 전에 거부됩니다
`get_current_user_optional()`은 **고치지 않음**	이 함수가 `get_current_user()`를 부르고 실패하면 손님으로 처리하므로, 무효가 된 토큰은 자동으로 손님이 됩니다(시험으로 확인)

선택	이유
401이면 화면이 재발급을 시도하는 점	`api.js`는 401을 받으면 `/auth/refresh`로 토큰을 다시 받으려 합니다. 리프레시 토큰도 **다음 함수**에서 같은 검사로 거부해야 합니다. 그 전에는 재발급이 성공해 이전 기기가 계속 로그인된 채로 남습니다

중요: 이 함수만으로는 아직 완전하지 않습니다. 액세스 토큰은 30분이면 만료되지만 리프레시 토큰은 3일 동안 새 액세스 토큰을 받아 갑니다. `/auth/refresh`를 고치기 전까지 이전 기기는 재발급으로 로그인을 이어 갈 수 있습니다. 다음 함수에서 닫습니다.

4. 시험

`test_deps.py` **6개 추가**(파일 전체 19개)

확인	결과
재설정 이전에 발급된 토큰은 같은 401	✓
재설정 이후에 발급된 토큰은 통과	✓
재설정과 같은 초에 발급된 토큰은 통과(재설정 직후 새 로그인이 쫓겨나지 않음)	✓
재설정한 계정에서 `iat`가 없는 토큰은 401	✓
재설정한 적 없는 계정은 `iat`가 없어도 통과	✓
`get_current_user_optional`은 무효 토큰을 손님으로 처리	✓

실제 앱과 실제 MySQL로 한 통합 시험 1개(`test_password_reset_service.py`)

1. 한 시간 전에 발급된 토큰으로 `/api/v1/me/dashboard` 요청 → 200 (재설정 전)
2. `reset_password()` 실행
3. 같은 토큰으로 다시 요청 → **401**
4. 재설정 뒤 새로 발급한 토큰으로 요청 → **200**

기존 시험의 가짜 회원(`SimpleNamespace`)에는 `password_changed_at=None`을 더했습니다. 새 검사가 이 칸을 읽기 때문입니다.

시험을 확인하는 시험. 일부러 틀리게 바꿔 시험이 잡는지 보았습니다.

바꾼 것	결과
재설정 검사 제거	3개 실패
검사 결과를 반대로	8개 실패
`iat` 대신 `None`을 넘김	2개 실패
액세스 토큰을 `"refresh"` 종류로 해독	5개 실패

전체 pytest 781개 통과, `ruff` 통과.

5. 시험을 고치며 있었던 일

줄 길이를 맞추려고 줄 번호로 `sed`를 돌렸다가, 번호가 어긋나서 엉뚱한 줄(시험의 구역 설명 주석)을 덮어쓴 것을 `grep`으로 발견해 복구했습니다. 156번 작업에서 같은 실수를 한 뒤 두 번째입니다. 이후로는 줄 번호가 아니라 **내용으로 찾아 바꾸는** 방식(`str.replace`)만 씁니다. 최종 시험은 그대로이고 복구 뒤 전체 시험을 다시 돌려 통과를 확인했습니다.